

Ransomware Incident Analysis — CryptoLocker

Malware Analysis & Incident Report

Author: Pasin Visuttipinate

Conducted in an authorized, isolated lab environment.

1. Executive Summary

A security incident occurred involving the execution of a malicious file (suspected.exe). The file was delivered through an internal email and unknowingly executed by multiple employees. Analysis of the evidence indicates the malware belongs to the **CryptoLocker** family of ransomware — a well-documented, file-encrypting threat targeting Windows systems.

The primary business impact of CryptoLocker is loss of access to data through file encryption. Once executed, it establishes persistence so it runs at every logon, contacts an attacker-controlled server to obtain an encryption key, then encrypts the victim's files. A ransom note then demands payment in exchange for the decryption key.

Paying the ransom is **not advisable**: there is no guarantee the attacker will honor it, and payment fuels further attacks. Affected data should instead be restored from backups where available.

Key risks include operational disruption from affected workstations, potential loss of sensitive data where no backup exists, financial loss from downtime and recovery, and reputational damage if customers are affected. It is strongly recommended that affected devices be **immediately isolated** and the malware eradicated, with data restored from backups. In the longer term, the organization should strengthen email security, user (phishing) awareness, endpoint controls (EDR), and backup resilience.

2. Technical Analysis

2.1 Behavior Analysis

Analysis of the evidence (strings, registry snapshot, and capa output) indicates a ransomware targeting Windows that encrypts files using RSA and AES. Recovered strings show the victim is presented with information about what happened, the amount to pay for decryption, and payment instructions.

2.2 Capabilities

- Packed to hinder static analysis.
- Capable of sleeping, suggesting attempts to evade dynamic analysis.
- Modifies the registry to run automatically at start-up (persistence).
- Connects to a remote host/server, likely to receive a public key for RSA encryption.
- Includes target file extensions (e.g., .doc, .ppt), indicating intent to maximize business damage.
- The presence of GetKeyState indicates an additional keylogging capability.

2.3 Registry Modifications

The malware achieves persistence via a Run key, ensuring execution on every start-up:

```
HKU\...\SOFTWARE\Microsoft\Windows\CurrentVersion\Run\CryptoLocker:  
"C:\Users\<user>\AppData\Roaming\{GUID}.exe"
```

The remaining registry changes appear to be normal behavior or unrelated to this malware.

2.4 Threat Identification

The malware is a ransomware: it encrypts user data and then makes itself explicitly known to demand a ransom. Lookups of the sample's hashes on VirusTotal confirm it as CryptoLocker, supported by a literal CryptoLocker string and the matching registry key name.

2.5 Indicators of Compromise (IOCs)

Type	Indicator	Notes
File	suspected.exe	Initial email attachment.
File path	C:\Users\<user>\AppData\Roaming\{GUID}.exe	Installed copy used for persistence and execution.
Registry	... \CurrentVersion\Run\CryptoLocker	Run-key autorun pointing to the installed copy.
String	CryptoLocker	Malware family name present in strings.
String	Ransom note referencing a unique public key and a private key required to decrypt	Sample of the ransom messaging.
String	Payment references (Bitcoin and named voucher services)	Part of the payment instructions.
Behavior	Persistence via Run-key autorun	From capability analysis.
Behavior	Encryption via WinCrypt (AES) with RSA public-key import; SHA-1 hashing; Mersenne-Twister RNG	Key indicators of the encryption routine.
Behavior	File discovery — enumerate, copy, and delete files recursively	Indicators of file processing.
Behavior	Network — WinHTTP requests/responses to a command-and-control host	Indicators of C2 communication.
Behavior	Keylogging via polling	Indicator of the keylogging capability.

Sample hashes (public IOCs) are retained in the original evidence and were verified against VirusTotal.

3. Defense Recommendations

3.1 Containment & Eradication

- **Isolate all affected machines immediately.** Although the sample shows no self-propagation, isolation is prudent and supports clean analysis.
- **Remove affected devices from the network,** since the malware relies on contacting its server to obtain the RSA public key; in rare cases this can prevent encryption.
- **Rebuild affected machines** from a known-good image.

3.2 Recovery

- **Restore affected data from prior backups** once the malware is eradicated and systems rebuilt.
- **Inventory the encrypted files** so the organization can track the damage even where recovery is not possible.

3.3 Prevention

- **Strengthen email security:** block or quarantine executable attachments, enable phishing detection, and use sandboxing.
- **Deploy EDR** to detect and prevent suspicious behavior.
- **Perform regular, tested backups.**
- **Train employees** to recognize phishing emails.